PROPOSAL IMPLEMENTATION AND MIGRATION ASSURANCE

API3 DAO migration audit

Final report | Codex review

Prepared by: API3 leadership team

Version: 1.2

Review dates: 26-28 October 2026

Report date: 28 October 2026

Assessment status: Complete. AUD-02 and AUD-03 mitigated. Other dispositions recorded.

Review target: api3dao/api3-dao-migration-proposal

Source revision:
`4740c29551fc8be8bd21ecab9d5baeec8d8460d2`

Reference network: Ethereum mainnet, chain ID 1

Reference block: 26,287,968

Conclusion: review complete for the stated source revision.

The tested migration path succeeds. All four findings and their history are retained. AUD-02 is mitigated by removing the primary's dependency on PNK and wPOKT transfers. AUD-01 remains an accepted risk. Remaining asset-balance and transfer-availability checks are execution preconditions. AUD-03 is mitigated by the explicit build-block verification fallback, with authenticated generation records still required. AUD-04 requires complete metadata before proposal posting.

This report assesses the source revision and reference state identified above. It records tested mitigation, acknowledged risks, and the operating requirements for preparing and executing the proposal. Verification of the actual posted vote is a separate release step. No transaction was signed or broadcast during the review.

1. Executive conclusion

The reviewed implementation builds one primary Aragon CallsScript containing 26 calls. Posted secondary votes 133 and 134 separately transfer PNK and wPOKT to the Agent Safe. On its intended path, execution transfers the listed treasury assets, makes the one-time API3 mint, removes the pool and primary Agent from the minter set, transfers token ownership to the dead address, disables new legacy proposals, and removes selected root permissions.

The baseline suite passes all 28 existing tests at the frozen reference block. The complete review suite passes all 49 tests, including the original 12 added audit checks and nine new remediation checks. The new checks cover all six execution orders of the two posted secondaries and the primary, generation after the tokens are emptied, exact secondary payloads, and independence from reverting token contracts. Passing observation tests confirm the recorded behavior. The acknowledged findings remain technically present where no code remediation is recorded.

The migration moves governance to Snapshot and preserves the staking mechanisms intended to supply voting power there. AUD-01 concerns the execution authority of Aragon proposals created before migration. In simulation, one such proposal obtains approval afterward and changes a pool exit parameter through surviving Agent permissions. The proposal author accepts this risk and intends to urge voters to reject unrelated competing Aragon proposals and support the reviewed migration and designated token-transfer secondaries. This social mitigation leaves the demonstrated technical capability in place.

AUD-02 is mitigated in commit `c6d977f`, merged as `a920489`, for the primary's dependency on PNK and wPOKT. PNK and wPOKT reads, nonzero-balance requirements, and transfers are removed from the primary. Their token restrictions can therefore no longer block primary generation or execution. The remaining primary API3, USDC, and ETH transfers use fixed amounts. Later deposits alone do not prevent execution and are accepted without an automatic sweeping requirement. Balance sufficiency and USDC transfer availability remain execution preconditions. The separate token proposals retain their own transfer risks. AUD-03 is mitigated by the build-block fallback in `7b14436`, merged as `4740c29`. Seventeen CLI scenarios exercise the real verifier on locally posted votes. Generation-block hash and artifact authentication remain operating requirements. AUD-04 is acknowledged as a release preparation item requiring complete metadata before posting.

The proposal author confirmed that 200,000,000 API3 is a target subject to holders burning tokens and to an explicit Treasury Safe cleanup burn if additional rewards are minted before execution. Supply drift is therefore documented as an acknowledged design condition rather than a separate defect requiring exact supply at atomic execution.

Final dispositions and execution conditions

AUD-02 has a tested mitigation: the primary no longer calls or reads PNK or wPOKT. AUD-01 remains an accepted design risk. AUD-03 now has a tested build-block fallback. Its remaining provenance requirements and AUD-04 release preparation are recorded in section 4. Original severities, acknowledgments, and technical evidence are retained. Fixed-amount asset handling and later donations are accepted design conditions.

This completes the review of the identified revision. Proposal preparation and execution must follow section 7, including verification against the approved generation state, complete voter-facing metadata, and fresh execution precondition checks. Source or metadata changes are assessed under the revision protocol in Appendix C.

Reading guide

Sections 2 and 3 define scope and intended behavior. Section 4 records the findings and remediation history. Section 5 describes validation and coverage. Sections 6 and 7 contain assumptions and release gates. The appendices identify addresses, payload provenance, and the final retest protocol.

2. Scope and review boundaries

Subject of the review

The subject is the migration feature at the cover revision. Version 1.2 carries forward the prior source review and examines the two-file change from `a920489` to `4740c29`: verifier code and README instructions. Migration generation and execution bytes are unchanged.

The existing Aragon DAO, API3 token, and staking pool are inspected only to establish migration preconditions, interface behavior, authority relationships, and post-migration compatibility. Existing behavior is reported as a finding only when it prevents the proposal from satisfying its stated migration requirements or undermines its preparation and verification workflow.

In scope	Review purpose
`src/MigrationScript.sol` and `src/Interfaces.sol`	Call order, callers, destinations, amounts, minting retirement, transition of governance to Snapshot
`script/CreateVote.s.sol` and `script/VerifyVote.s.sol`	Payload generation, metadata construction, generation provenance, posted-vote verification
`proposal/title.txt` and `proposal/description.md`	Exact metadata committed by the proposal
`scripts/*.mjs` and `scripts/pick-voters.sh`	Decoding, README consistency, voter-fixture preparation
`test/`, `foundry.toml`, setup and test scripts, CI, README	Assertions, execution paths, reproducibility, documented claims
Existing DAO dependencies at the reference block	Necessary integration behavior and preconditions for this migration
Posted secondary votes 133 and 134	Exact transfer scripts, recipients, amounts, immutable descriptions, and interaction with primary execution

Exclusions

Other related repositories are outside the source review. Snapshot space configuration, strategies, delegation rules, future proposal execution, multisig operations, signer key management, replacement governance implementations, and the complete TimelockManager implementation are external dependencies. Their effects on migration readiness are recorded explicitly rather than certified by this report.

This work does not assess the current deployment as a general vulnerability-discovery target. It does not examine unrelated live applications, develop a production attack, or submit an on-chain action. The added tests operate on a local fork and synthetic local scenarios. No claim is made that a competing vote used in a test exists on mainnet.

Review identity and independence

The report is prepared by the API3 leadership team using source inspection, public explorer references, Foundry, and Codex-assisted analysis and test orchestration. It is an internal technical assessment. It does not represent independent assurance or an attestation by an external auditing firm.

3. Intended transition and acceptance criteria

The intended future behavior is governance through Snapshot, permanent termination of API3 minting, and continued operation of staking-pool user actions without new minted rewards. New proposals are disabled on the legacy Aragon voting apps. Staking-based voting power is intended to remain usable in Snapshot, subject to its external configuration. Remaining Aragon proposal authority and treasury balance-change risks are acknowledged and accepted as described in section 4.

ID	Acceptance criterion	Assessment of reviewed revision
GOV-1	New proposals cannot be created on either legacy voting app through any public creation route	Pass in tested fork paths
GOV-2	Remaining execution authority of pre-migration Aragon proposals is identified and its migration risk is expressly accepted or eliminated	Accepted risk, AUD-01. Competing proposals should be rejected through the governance process
GOV-3	Staking-based voting power remains available for the intended Snapshot governance system	Pool stake/share accounting and delegation remain operational in tested flows. Snapshot configuration is an external dependency
TOK-1	The pool and primary Agent cannot mint after execution	Pass at the reference state
TOK-2	No other active minter survives and minting cannot be reauthorized	Historical reference evidence supports the known minter set. Final execution preflight remains required
SUP-1	Supply targets 200M API3 with acknowledged burns and documented overshoot cleanup	Conditional, acknowledged target. Operator cleanup remains external
AST-1	Primary API3, USDC, and ETH transfers reach the intended Safes. PNK and wPOKT move through designated secondaries	Pass in tested paths without intervening drift. All six execution orders pass. PNK/wPOKT dependency mitigated under AUD-02. Fixed-amount execution checks remain in section 7
POOL-1	Existing balances, stake, shares, reward locks, and exit rights survive migration	Pass for tested migration flows. Continued authority of older Aragon proposals is separately accepted under AUD-01
POOL-2	Deposits, staking, unstaking, withdrawals, delegation, and pool-side vesting interfaces remain usable	Pass in the covered scenarios. Manager-side execution is excluded
META-1	The final voter-facing text is complete and corresponds to the exact payload	ACK, release preparation requirement under AUD-04
VER-1	A correctly generated posted proposal can be independently matched to its reviewed source and generation state	Mitigated under AUD-03 through the build-block overload. Snapshot guards and authenticated generation records remain required

Migration architecture and authority

Calls	Action	Required caller
1-2	Give the primary Agent transfer and execution access to the secondary Agent	Primary voting app calls ACL
3-4	Move secondary Agent USDC and ETH to the Agent Safe	Primary Agent, then secondary Agent
5	Move the primary Agent's API3 to the Treasury Safe	Primary voting app calls primary Agent
6-10	Remove pool minting, temporarily enable the primary Agent, mint to the Treasury Safe, disable Agent minting, transfer ownership	Primary Agent as token owner
11-14	Revoke wildcard vote creation and remove its managers	Primary voting app calls ACL
15-22	Raise support and quorum on both apps, remove their managers	Primary Agent changes settings, voting app removes managers
23-26	Revoke Kernel app-management and ACL permission-creation roles and remove managers	Primary voting app calls ACL

CallsScript execution is atomic. A failing call rolls back the proposal's execution. The fixed list of treasury balances and the fixed mint amount are read when the script is generated. They are not recomputed by the script at execution.

Posted secondary proposals and execution order

Both secondary votes were open and unexecuted at reference block 26,287,968. Their exact on-chain scripts were decoded and compared byte for byte with the intended transfers. Each script has one CallsScript entry calling the secondary Agent's `execute`, which calls the relevant token's `transfer` with zero ETH value. Both recipients are the Agent Safe `0xbbe0de9757f93e3306adbfebe906ab285edd13da`.

Secondary vote	Encoded transfer	Creation block	Observed status
133	1,547,987 PNK, `154798700000000000000000` base units	26,285,795	Open, unexecuted
134	249,999.99 wPOKT, `249999990000` base units	26,285,961	Open, unexecuted

Creation transactions are vote 133 and vote 134. The creators are distinct from one another and from the Vault Safe intended to post the primary. The Vault's observed cooldown and snapshot voting power permit proposing at the reference state. Eligibility must be checked again at submission.

The descriptions linked in the creation events were retrieved and their bytes verified against their raw SHA-256 IPFS CIDs. The PNK description and wPOKT description accurately specify the token, recipient, and encoded amount. Both describe a later sale for USDC by the Agent Safe. That sale is a separate operator action and is not encoded or assured by these proposals.

The intended operational sequence executes both secondaries before the primary. All six permutations were tested successfully on a local fork with simulated holder approvals, including the primary executing first and either secondary executing afterward. The existing secondaries retain their stored support and quorum and the secondary Agent execution permission after migration. This is a specific intended use of the authority retained under AUD-01. It does not eliminate that finding's wider risk.

The primary has no on-chain condition forcing either secondary to execute first. Anyone can execute an approved vote. Each reviewed secondary stores 50% support and 15% acceptance quorum and has a seven-day voting period. Early execution requires strictly more than 50% of total snapshot voting power voting yes. Later execution follows the vote's stored support and quorum rules. A token restriction or changed balance can still prevent a secondary from executing. After the primary disables new proposals, an unusable secondary payload cannot simply be replaced with a new vote. Intended prior execution remains an operating control, not a protocol guarantee.

Authority retained by the reviewed script

The following permissions explain how Aragon proposals created before migration can retain execution authority after new proposal creation is disabled. The reference ACL history identifies the original grants and managers. The script leaves the listed paths in place or adds them during migration. Added local post-state checks confirm the key Agent and registry permissions described by the accepted finding AUD-01.

Authority holder	Remaining permission or relationship
Primary voting app	Primary Agent execution, script-running, and transfer roles, with the primary voting app retaining their managers
Secondary voting app	Secondary Agent execution, script-running, and transfer roles, managed by the primary voting app
Primary Agent	Newly granted execution and transfer roles on the secondary Agent
Primary Agent	Support and quorum modification roles on both voting apps. The migration removes their managers but retains the role grants
Primary voting app	Script-registry executor-addition and registry-management permissions, with their managers retained

The migration removes the primary voting app's Kernel app-management and ACL permission-creation grants and their managers. Those removals do not erase other existing grants. The proposal author's acceptance of AUD-01 includes the surviving relationships described here.

4. Findings and final dispositions

Severity model

Severity combines impact on the migration's stated requirements and the conditions needed for the effect to occur. High denotes a material failure of authority retirement or protection of user funds or exit rights. Medium denotes a material preparation, verification, execution, or asset-completeness failure under plausible state changes. Low denotes a limited defect that still needs correction or an explicit readiness decision. Critical would require an immediate or broadly reachable catastrophic outcome. No critical finding was confirmed in this review.

The governance finding requires a previously created legacy proposal and sufficient approval under its original thresholds. It is not a claim of permissionless control by an arbitrary account.

The dispositions distinguish the tested mitigations of AUD-02 and AUD-03 from accepted risks and release requirements. Original acknowledgments remain in the finding history. Technical mitigation is supported by the identified source change and retest.

Finding	Severity	Disposition	Remaining effect or requirement
AUD-01: Pre-migration Aragon proposals retain execution authority	High	ACK, risk accepted	Older proposals retain authority. Review outstanding proposals and urge rejection of competing proposals
AUD-02: Primary execution depended on PNK and wPOKT	Medium	Mitigated	PNK and wPOKT removed from the primary. Separate balance and transfer-availability preconditions remain
AUD-03: Snapshot reconstruction can reject unchanged payloads	Medium	Mitigated	Explicit build-block fallback tested. Retain block hash and artifact provenance. Snapshot amount guards still apply
AUD-04: Proposal description is a placeholder	Low	ACK, release preparation	Complete and review final metadata before posting

Finding history

Finding	Affected revision	Disposition or remediation	Retest result
AUD-01	`0e10333`	Accepted 26 October, reaffirmed 27 October	Reproduced, no technical fix
AUD-02	`0e10333`	ACK 26-27 October	Original observations retained
AUD-02	`c6d977f` / `a920489`	PNK/wPOKT isolated, 28 October	9 targeted checks and 49 fork tests pass
AUD-03	`0e10333`	ACK 27 October, now superseded	Original snapshot limitation retained
AUD-03	`7b14436` / `4740c29`	Build-block fallback, 28 October	17 CLI scenarios and 49 fork tests pass
AUD-04	`0e10333`	ACK 27 October. Final metadata required	Final metadata remains release preparation

AUD-01: Pre-migration Aragon proposals retain execution authority

Severity: High | **Disposition:** ACK, risk accepted
Code status: Unchanged
Affected: governance-transition calls in `src/MigrationScript.sol`
Requirement: GOV-2 | **First reviewed revision:** `0e10333`

Description. Raising each voting app's support and quorum changes defaults for subsequent proposals. The existing voting implementation stores support and quorum inside each proposal when it is created. Votes created earlier continue using those stored values. Removing permission to create new proposals does not prevent support or execution of an existing proposal.

The migration also leaves the voting apps' Agent execution, script-running, and transfer permissions in place. The primary voting app remains the manager of important Agent roles and retains script-registry permissions. Removing only the Kernel and ACL root roles does not remove these existing authorities or their surviving managers.

Observed effect. A local fork test creates a second Aragon proposal before executing the migration. The migration succeeds and blocks new Aragon proposal creation. The second proposal receives sufficient support afterward and changes the pool's unstake waiting period through the primary Agent. The test uses valid governance approvals and synthetic local state. It does not establish that such a competing proposal exists on mainnet. This finding concerns Aragon proposal execution. Staking-based voting power is intended to continue in Snapshot.

Conditions and impact. An Aragon proposal must have been created before migration and must obtain the support required by its own stored thresholds. Approved but unexecuted proposals also need consideration. Surviving Agent authority extends beyond the demonstrated parameter setter to pool administration, management of existing permissions, and script-registry administration.

Acknowledgment and mitigation. The proposal author accepts this risk on 26 October 2026. The operating expectation is that no competing Aragon proposal will be created. If one is created, the author intends to urge voters to reject it and support the reviewed migration and designated token-transfer secondaries. This is a governance-process mitigation. The contracts still permit an older proposal with sufficient approval to execute, and an already approved proposal is not technically disabled by this acceptance.

Acceptance rationale. On 27 October 2026, the author reaffirmed a preference for lower call count and calldata complexity over further permission-removal operations. This acceptance covers primary and secondary Aragon proposals. On 28 October, the revised plan explicitly includes designated PNK and wPOKT votes 133 and 134. Their execution after migration remains possible and was retested. Review of other outstanding proposals must include already approved but unexecuted proposals.

Technical remediation option. If technical elimination is later desired, remove the relevant Agent execution, script-running, transfer, and script-registry authorities and their restoration paths after the migration's last privileged call. Include both voting apps, surviving permission managers, and the primary Agent's newly granted secondary-Agent permissions. Preserve all intended pool user actions.

Retest if technically remediated. Test primary and secondary Aragon proposals created before migration, including already approved proposals. Confirm they cannot exercise the retired authorities or restore them, while pool user actions continue to work. No such fix is claimed for this accepted finding.

Evidence. `test_AUD01_PreMigrationVoteCanChangePoolSettingsAfterMigration` and `test_AUD01_AgentAndRegistryPermissionsAndManagersRemain` in the audit test harness. Reference sources include the deployed voting implementation's `_newVote`, `_canExecute`, and `vote` behavior, the Agent interfaces, and the ACL permission-manager model.

AUD-02: Primary execution depended on PNK and wPOKT transfers

Severity: Medium | **Disposition:** Mitigated
Code status: PNK and wPOKT removed from primary
Mitigation scope: PNK/wPOKT reads and transfers removed from primary
Requirement: AST-1 | **First reviewed revision:** `0e10333`

Description and original scope. PNK controller restrictions or wPOKT pausing could block the original primary. The initial report grouped this with fixed amounts under "Fixed treasury amounts can fail execution or leave assets behind". That history is retained. The final Mitigated disposition applies to removal of the PNK/wPOKT dependency.

Original observations. On a local fork, a later one-API3 deposit remains after successful execution. An authorized one-base-unit USDC reduction causes atomic rollback of the primary, preserving token ownership, pool minting, and proposal permissions. These fixed-amount observations remain part of the history and operating assumptions.

Impact before mitigation. Either token refusing its transfer could revert the complete primary. Additional deposits instead leave residuals and do not block fixed transfers. Removing all old authority under AUD-01 could make residuals inaccessible without an intentional recovery path.

Original acknowledgment. The author accepted fixed-amount treasury risk on 26 October and retained a single primary on 27 October. The reviewed mitigation supersedes inclusion of PNK and wPOKT in that primary. Fixed-amount asset handling and residual donations remain accepted design conditions.

Expanded ACK. On 27 October, the author accepted external transfer restrictions and residual donations. PNK controller restrictions and wPOKT pausing could block the original primary despite sufficient balances. They now affect the corresponding secondary transfer. A dynamic balance helper cannot override those restrictions. Recipient assets remain under Safe control.

Mitigation and retest. Commit `c6d977f`, merged as `a920489`, removes both token constants, balance reads, positive-balance requirements, and transfers. Amount output and baseline assertions are updated. The 26-call primary is 4,316 bytes. Remaining calls, recipients, and privileges are unchanged apart from renumbering. Secondaries 133 and 134 carry the removed transfers. Nine checks validate their exact payloads, all six execution orders, generation after emptying both tokens, primary-only balance preservation, and primary success with both token contracts reverting. All 49 tests pass.

Accepted operating assumptions. API3, USDC, and ETH amounts remain fixed. Later deposits may remain and do not block execution, as accepted by the author. Sufficient balances and USDC transfer availability remain execution preconditions. Each secondary retains its token-policy dependency. The original Medium severity is historical. The primary's PNK/wPOKT dependency is mitigated.

Recommended operating checks. Recheck balances before posting and execution. Address shortfalls or approve a replacement before new proposals are disabled. Report residual assets. Review recipient restrictions and retained authority if a later design adds dynamic sweeping or recovery.

Future design changes. Changes to dynamic sweeping or recovery require tests of increases, decreases, zero and unchanged balances, atomic rollback, recipient restrictions, and retained authority. Rebuild and compare the final call table after any payload change.

Evidence. The original `test_AUD02_DonationAfterBuildingLeavesResidualTreasuryBalance` and `test_AUD02_BalanceReductionBeforeExecutionRevertsEntireMigration` remain unchanged and pass against the revised primary. Nine new scenarios in `SecondaryMigration.t.sol` validate the mitigation using the actual posted scripts. Baseline assertions cover the unchanged-balance case, and the existing zero-USDC test confirms generation rejects one zero-balance case.

AUD-03: Snapshot reconstruction can reject an unchanged payload

Severity: Medium, original | **Disposition:** Mitigated
Code status: Explicit build-block fallback implemented
Affected: `script/VerifyVote.s.sol`, generation provenance
Requirement: VER-1 | **First reviewed revision:** `0e10333`
Mitigation: `7b14436`, merged as `4740c29`

Original finding. Generation reads amounts at the build block, while the original verifier reconstructed only at the proposal's snapshot block. A relevant balance or supply change could therefore reject an unchanged, correctly generated payload. Different block numbers alone do not imply different payloads. The initial generation/snapshot observation tests and the author's 27 October acknowledgment remain part of the history.

Mitigation. The new overload, `run(voteId, buildBlock)`, keeps snapshot reconstruction as its first check. If that differs, it requires the supplied build block to be no later than the snapshot, rebuilds at that block, and compares the complete script hash. It reports changes to the mint, primary Agent API3, secondary USDC, and secondary ETH amounts. Creator and metadata checks remain in place. The original one-argument form remains available and instructs the operator to use the overload when amounts differ.

CLI retest. The actual Forge verifier was run against synthetic votes posted on a private Anvil fork. Seventeen scenarios pass their expected assertions. Unchanged same-snapshot and delayed votes verify. Explicit build-block verification succeeds after ETH and USDC changes, a primary Agent API3 change, a holder burn, and a reward mint. Altered script bytes, altered metadata, an incorrect creator, a nonexistent vote, zero build block, and incorrect or future fallback blocks are rejected. The legacy form correctly rejects the drift case and requests the new overload. These are local simulations, not verification of the final mainnet primary.

Retained limits. The argument is a fallback hint, not an unconditional provenance pin. When snapshot bytes already match, the supplied positive build block is not consulted. A tested future hint is therefore ignored on that path. The verifier also calls `readAmounts()` at the snapshot before trying fallback. Its positive-balance and supply guards still apply. A tested zero-USDC snapshot rejects verification before the otherwise valid build reference can be used. The earlier payload can remain authentic despite this rejection. Investigate the snapshot guard and execution preconditions separately.

Operating requirement. Retain the approved generation block number and hash, source revision, script hash, amounts, and exact metadata. The overload does not authenticate the supplied block against an approval record or take an expected block hash. Keep the voting snapshot as the reference for voting power and creation-event lookup. Independently recheck execution state and investigate any guard failure. The actual posted primary must still be matched to the approved release bundle after posting.

Disposition. The source change mitigates the original false-rejection problem for relevant drift while snapshot generation preconditions hold. The remaining guards and provenance duties above are explicit limits of that conclusion. No execution call or asset amount calculation was changed by this verifier update.

Evidence. The original `MigrationAudit.t.sol` observations remain unchanged. `test_verify_vote.py` invokes the unmodified production verifier CLI, checks real local creation logs, and records all 17 results. The local fork uses chain ID 31337 and immutable storage cached at the matching Ethereum reference to avoid repeated archive reads. No mainnet transaction was signed or broadcast.

AUD-04: The proposal description is still a placeholder

Severity: Low | **Disposition:** ACK, release preparation
Reviewed state: Description placeholder acknowledged
Affected: `proposal/description.md`, line 1
Requirement: META-1 | **First reviewed revision:** `0e10333`

Description. The committed description is `TODO: IPFS link`. Generation and tests accept this as a nonempty description. The resulting metadata can therefore pass the current structural checks without communicating the reviewed migration intent or linking to the final proposal text.

Acknowledgment and release requirement. The placeholder is a known proposal-preparation item. Complete text or an immutable reference must be supplied, checked against the approved payload, and bound to its metadata hash before posting. The implementation review is complete with this item acknowledged, reaffirmed by the proposal author on 28 October 2026. The final voter-facing primary metadata has not been reviewed in this assessment. Completing it requires a release-time content and payload-consistency check. That preparation does not by itself require reopening the unchanged functionality assessment.

Impact. The report cannot establish that voters will receive complete, matching information about asset recipients, irreversible minting retirement, retirement of legacy authority, and post-execution cleanup. Finalizing the metadata also changes what the posted-vote verifier expects and must be reflected in the approved release bundle.

Recommended remediation. Supply the final description and, if it uses an IPFS link, the exact immutable content it identifies. Review that content against the final payload, assumptions, recipients, and operating sequence. Regenerate metadata and retain its exact bytes and hash. Add a preparation check that rejects known placeholders and empty final content.

Required retest. Rebuild the metadata from the final files, decode its version and delimiters, compare its hash with the approved bundle and posted event, and verify that the referenced proposal content is accessible and matches the reviewed text.

Evidence. `proposal/description.md:1`, `CreateVote.run`, and the metadata tests in `test/vote/script.t.sol`. No final IPFS content was supplied or reviewed.

Although the technical severity is low, complete final metadata is a mandatory release gate. This finding can be resolved without changing any execution call.

5. Validation and coverage

Methodology

The review follows the source-generated payload through its callers, nested Agent calls, token operations, permission changes, and post-migration pool interfaces. Deployed dependency sources were obtained from public explorers and checked against the required interface behavior. Read-only reference calls identify the implementation addresses and relevant preconditions at the frozen block.

The baseline suite was run separately from the supplemental audit tests. Additional tests use a local Ethereum fork, legitimate holder voting power, and controlled local changes that represent plausible migration timing and integration conditions. Impersonating holders and Safes verifies contract behavior under those callers. It does not verify signatures, signer availability, Safe transaction construction, or an operator's future actions.

Reference evidence includes block and code hashes, source-file hashes, minter and claims-manager event histories, ACL grants and managers, Safe owner lists and thresholds, token balances, and pool configuration. The reference RPC returned one historical minter-status event, enabling the staking pool, and no historical claims-manager-status events through the frozen block. These are reference-state observations, not guarantees about later state.

Validation results

Check	Result and significance
Foundry compilation	Pass with Solidity 0.8.20. Existing linter warnings remain documented below
`forge fmt --check`	Pass
`bulloak check test/*/*.tree`	Pass for the repository's existing branching-tree specifications
Original fork suite, pinned block	28 passed, 0 failed, 0 skipped
Original added audit and compatibility checks	12 passed, 0 failed, 0 skipped against the revised implementation
Secondary-split remediation checks	9 passed, 0 failed, 0 skipped, including all six execution orders
Complete pinned review suite	49 passed, 0 failed, 0 skipped against `4740c29`
Production verifier CLI integration	17 local scenarios pass their expected success or rejection assertions. Includes the documented snapshot-guard and fallback-hint limits
README call table regeneration	Unchanged at reference block 26,287,968
Reference network check	Chain ID 1 confirmed. Captured dependency runtime hashes and proxy implementation addresses match the original review

Regeneration reproduces the unchanged 26-call script and committed README table. CLI checks use locally posted votes and RPC creation logs on chain 31337, with anchored original storage preloaded. Both real secondary scripts and their IPFS-verified descriptions were captured at the Ethereum reference. Mainnet approval, execution, or signer authorization is not inferred from these simulations.

The added audit harness is not described as bulloak-specification coverage. Its scenarios supplement the existing branching-tree specifications. The report does not claim formal verification, exhaustive path coverage, or a full end-to-end Safe-signature rehearsal.

User-action coverage

Behavior	Evidence and limits
Pool balances, total stake, shares, sample user stake and locked rewards	Added before/after accounting assertions
Existing staker full exit and reward vesting	Baseline tests cover seven-day waiting, lock limits, 26-epoch reduction, and full reward unlock after the vesting window
Partial exit, re-entry, and later full exit	Baseline scenario spans more than a year
New deposits and staking	Baseline and added scenarios cover `depositRegular`, `stake`, and `depositAndStake`
Pending unstake created before migration	Added test completes it after migration and withdraws unlocked funds
Separate and combined exits	Baseline `unstake` and `withdrawRegular`, added `unstakeAndWithdraw`
Delegation and undelegation	Added test updates delegation, respects the cooldown, and completes an exit
Expensive-lock withdrawal alternative	Added test completes `precalculateUserLocked` in chunks and uses `withdrawPrecalculated` for an existing staker
Pool-side vesting integration	Added test calls `deposit`, `depositWithVesting`, and `updateTimelockStatus` as the existing manager. The manager implementation and real manager transactions are excluded
Reward cessation	Baseline calls advance epochs without minting and preserve stake. Added compatibility flows retain the expected total supply
Proposal creation	Four-argument creation is covered by the baseline. Added checks cover the two-argument overload and forwarding on both apps

Material limitations and existing warnings

The baseline linter reports a narrowing cast for CallsScript length and warnings about block/time reads around Foundry time travel. The reviewed script has bounded, fixed call sizes far below the 32-bit length limit. The time-travel warnings concern test methodology and were not suppressed. No production fix or test weakening was made to obtain passing checks.

Tests use representative accounts and synthetic local states. They do not prove behavior for every historical user's checkpoint layout, every possible future state, or every third-party token policy. Some existing integration tests exercise a single qualifying staker chosen from the fixture. No claim of complete user-state enumeration is made.

This completed assessment applies to the identified source revision and reference state. It does not establish exhaustive defect detection. Final proposal metadata, an actual posted vote, later source revisions, and execution-time state require the checks specified in section 7 and Appendix C.

6. Assumptions and acknowledgments

Acknowledgment means the proposal author accepts a stated dependency and its effect. It does not turn an external system into audited code or mark an unmet mandatory criterion as passing.

ID	Assumption or operating dependency	Status
A-01	200M API3 is a target subject to holder burns and overshoot cleanup, rather than an exact atomic invariant in every state	Acknowledged by the proposal author on 26 October 2026
A-02	The three recipient/proposer Safe addresses are the intended operational wallets, and the required owners remain available to act	Address configuration observed at reference block. Confirm custody intent and operator availability before posting
A-03	If rewards increase supply after generation, the Treasury Safe will opt into burning if needed and burn the calculated excess. It will retain enough API3 to do so	Cleanup principle acknowledged. Confirm operating responsibility and available balance before execution
A-04	Snapshot governance is configured and ready, with the intended voting strategies, proposer authority, delegations, and treatment of treasury voting weight	External operational dependency. Confirm the release configuration and record its reference
A-05	The generation, posting, and execution references are authenticated and relevant state is rechecked before execution	Use the build-block overload when reconstruction differs under AUD-03. Retain authenticated generation records. Fixed amounts and residual donations are accepted design conditions
A-06	Existing TimelockManager-side operations remain available where needed. The migration does not change its pool-side integration permissions	Pool-side compatibility tested. Manager-side implementation and end-to-end operation are external dependencies
A-07	No party controls the dead-address token owner, and no unexpected active minter is introduced between reference capture and execution	Standard ownership-retirement assumption, supported only for the captured known minter state. Final preflight required
A-08	The intended sequence executes secondaries 133 and 134 before the primary. Any later sale of the received tokens for USDC is an Agent Safe operator action	Operational intent recorded. Execution order is not enforced, and token-sale execution or proceeds are outside this assessment

Reference observations about Safe custody

At the reference block, the Vault, Treasury, and Agent Safes report the same set of five owners and a threshold of three. The queried first module page is empty for each Safe. These checks support the stated recipient configuration. They do not establish who controls the owner keys, guarantee owner availability, or constitute a full Safe configuration audit. Guards and fallback handlers were not exhaustively reviewed.

The Treasury Safe is deployed and has zero API3 before migration at the reference block. Its burner status is false. The token permits an address to opt into burning independently of token ownership, and the fallback fork scenario succeeds with that opt-in after migration. A real cleanup burn remains a separate operator action.

7. Execution requirements

Operating controls

1. Under AUD-01, identify designated secondaries 133 and 134 separately from unrelated competing proposals. Review all outstanding primary and secondary proposals, including already approved but unexecuted proposals, and apply the stated governance-process mitigation.
2. Check actual balances and transfer availability for primary API3, USDC, and ETH, and separately for the PNK and wPOKT secondary transfers. Aim to execute both secondaries first and record their receipts. Do not assume their order is enforced. Record any shortfall, residual balance, or token restriction and the operating response.
3. Under AUD-03, retain the generation block and hash, source revision, script hash, and exact metadata. Use `run(voteId, buildBlock)` when snapshot reconstruction differs. The block argument is a fallback hint, so provenance authentication and investigation of snapshot guard failures remain separate duties.
4. Under AUD-04, replace the description placeholder and review the complete immutable proposal text against the exact script before posting.
5. Confirm the external operating dependencies in section 6, including Snapshot configuration, Safe operators, cleanup responsibility, and the TimelockManager boundary.
6. Preserve the approved source and artifact bundle. Review later source or metadata changes and rerun the affected checks and full suite under Appendix C before reusing the report's conclusion.

Before proposal submission

1. Confirm chain ID, generation block hash, contract implementations, token ownership, complete current minter set, required ACL permissions, and the Vault's ability to propose at the actual snapshot. The seven-day proposer cooldown is shared across both voting apps. Keep the primary proposer eligible for submission.
2. Confirm all listed balances and recipient addresses under the adopted drift policy. Check that the Treasury Safe can receive the assets and perform any required cleanup.
3. Approve the exact CallsScript bytes and hash, metadata bytes and hash, source revision, amounts, and intended `newVote` arguments. `CreateVote` currently emits the script and metadata separately rather than a fully encoded `newVote` transaction.
4. Ensure proposal submission uses the approved payload. This review does not authorize a signature or a broadcast.

After posting and before execution

1. Match the posted script, metadata event, creator, and generation provenance to the approved bundle using the generation-block verification procedure required by AUD-03.
2. Recheck balance and supply drift, minters, external token conditions relevant to transfer success, competing legacy proposals, and all execution preconditions.
3. Simulate the exact posted payload against a fresh reference block using the final acceptance criteria and adopted operating constraints.
4. Confirm the cleanup owner and procedure if the supply will exceed the target. Any required mainnet action needs a separate explicit authorization.

After execution

Verify recipient credits and receipts for all three votes, residual Agent balances, token ownership, the full minter set, disabled new proposal creation, and pool accounting. Record remaining Aragon authority under AUD-01. Retain proposal IDs, transaction and block hashes, any separately authorized cleanup burn and resulting supply, and the final Snapshot configuration reference.

Appendix A. Address and implementation reference

Addresses were cross-referenced with public block explorers. Proxy implementation addresses are read at the frozen block. Explorer labels alone are not used as proof of identity.

Dependency	Address
API3 token	`0x0b38210ea11411557c13457d4da7dc6ea731b88a`
Staking pool	`0x6dd655f10d4b9e242ae186d9050b68f725c76d76`
Primary voting app	`0xdb6c812e439ce5c740570578681ea7aadba5170b`
Secondary voting app	`0x1c8058e72e4902b3431ef057e8d9a58a73f26372`
Primary Agent	`0xd9f80bdb37e6bad114d747e60ce6d2aaf26704ae`
Secondary Agent	`0x556ecbb0311d350491ba0ec7e019c354d7723ce0`
ACL	`0x1e7ecc6d3b5b4cfdfc71cb7c3ea9ac4a55f4195a`
Kernel	`0x593ea926ee9820a933488b6a288433c387d06dba`
Script registry	`0x3d9aa440ecbbf7927200610cdd79a5a7c2388aad`
Vault Safe	`0x8e03609ed680b237c7b6f8020472ca0687308b24`
Treasury Safe	`0xb7fa2cb302c5dc127e61f27b92bec411cbf0ae4a`
Agent Safe	`0xbbe0de9757f93e3306adbfebe906ab285edd13da`
USDC	`0xa0b86991c6218b36c1d19d4a2e9eb0ce3606eb48`
PNK	`0x93ed3fbe21207ec2e8f2d3c3de6e058cb73bc04d`
wPOKT	`0x67f4c72a50f8df6487720261e188f2abe83f57d7`
Token ownership destination	`0x000000000000000000000000000000000000dead`

Both voting apps use implementation `0xc215c66b455e9f7854e7870631f2a01878b0521a`. Both Agents use `0x3a93c17fc82cc33420d1809dda9fb715cc89dd37`. The ACL implementation is `0x81f7564e413586f1f99fde55740ac52b43ca99c9`. The Kernel implementation is `0x2b33cf282f867a7ff693a66e11b0fcc5552e4425`.

Primary source references

- API3 token explorer source.
- Staking pool explorer source.
- Voting implementation source.
- Agent implementation source.
- ACL implementation source.
- Kernel implementation source.

Explorer verification is not an independent audit of those dependencies. Some explorer results report partial or similar-source verification. In particular, the Treasury Safe's explorer source response is not marked as verified for that address. The report records its deployed code hash and observed interface configuration rather than treating its explorer source as fully verified.

Appendix B. Frozen payload and evidence provenance

Review anchor

Item	Value
Source revision	`4740c29551fc8be8bd21ecab9d5baeec8d8460d2`
Reference block	26,287,968
Reference block hash	`0xcca45235fa8658249b3ad57c038bb158350f9123801d353e417572f2c723248d`
Reference block time	28 October 2026, 08:34:59 UTC+7
CallsScript length	4,316 bytes
Number of calls	26
Script keccak256	`0xd5b3d6e60f527d3cc660f00a2b4e90779eb1d69b790c60e992b452b34ef924ae`
Foundry	Forge and Cast 1.8.5
Solidity compiler	0.8.20
Forge standard library	Setup pins tag v1.17.0
Branching-tree checker	bulloak 0.8.1

The script hash identifies the reference-generated execution bytes. It does not bind the final proposal description, a later generation block, or a future remediation revision. The current placeholder metadata must be replaced and separately approved.

Amounts encoded at the reference block

Amount	Integer base units
API3 minted to Treasury Safe	`10876876674326757910422715`
Primary Agent API3 to Treasury Safe	`6083873527701856751553400`
Secondary Agent USDC to Agent Safe	`59419713966`
Secondary Agent ETH to Agent Safe	`57118793443618210` wei

PNK and wPOKT are deliberately absent from the primary amount table. Their exact secondary amounts are recorded in section 3.

The initial total API3 supply is `189123123325673242089577285` base units. The fixed mint adds the difference to 200M API3. The amount table uses exact base units so no displayed decimal rounding can alter the reviewed values.

Appendix C. Review validity and subsequent revisions

This is the completed version 1.2 assessment of source revision `4740c29551fc8be8bd21ecab9d5baeec8d8460d2`, issued on 28 October 2026. Version 1.0 assessed `0e10333` with a 28-call primary. Version 1.1 assessed `a920489`, its 26-call primary, posted secondaries, and the mitigation of AUD-02. Version 1.2 reviews the two-file verification change in `7b14436`, merged as `4740c29`, and the tested build-block fallback under AUD-03. The source-generated execution bytes are unchanged from version 1.1. Original findings, severities, acknowledgments, and remediation history are retained, with the new verifier limits stated in section 4.

Each finding retains its original ID, affected revision, severity, evidence, and acknowledgment. A later remediation adds its exact commit, changed behavior, targeted regression result, and full-suite result. The original observation tests remain evidence for the reviewed revision. Accepted risks and operating requirements are separate from technical fixes.

For a newer branch, identify its exact commit and compare every in-scope change with this report's revision. Review the changed call sequence, asset list, recipients, permissions, supply calculation, generation and verification logic, and metadata as applicable. Run the target revision's static checks and full tests, reassess the recorded findings, and repeat relevant fork scenarios against an identified block and hash. Passing tests alone does not extend this report to the new revision.

Issue a versioned update identifying the new source revision, reference block, artifact hashes, material changes, test results, and finding dispositions. If an acceptance changes, retain the original record and add the superseding decision and rationale. The report applies to its stated revision until such an update is completed. Final proposal preparation and posted-vote verification remain subject to section 7.